



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



OXLOADER Malvertising Loader Distributing CASTLESTEALER

Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-06-22
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | OXLOADER Malvertising Loader Distributing CASTLESTEALER - Threat Intelligence Report

Published: 2026-06-22 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review & Confidence
4. Threat Actor / Campaign Overview
5. Tactics, Techniques, and Procedures
6. Infrastructure and Indicators
7. Victimology and Targeting
8. Detection Engineering
 - 8.1. Detection Summary
 - 8.2. Sigma / Detection Content
 - 8.3. Hunt Query
9. Threat Hunting
 - 9.1. Hunt Hypothesis
 - 9.2. Hunt Query
10. Risk Assessment
11. Recommended Actions
12. References

OXLOADER Malvertising Loader Distributing CASTLESTEALER

1. Executive Summary

Elastic Security Labs reports OXLOADER, a newly documented Windows loader distributed through malvertising and fake installers, delivering CASTLESTEALER. Public snippets describe PE .reloc abuse, multilayer obfuscation, VM/environment checks, Russian/CIS exclusions, and in-memory payload deployment.

This report was produced from current public reporting available during the 2026-06-22 UTC automation window. It does not add unverified IOCs or attribution claims beyond the cited sources.

2. Intelligence Requirements

Question	Current Answer	Confidence
Who is affected?	Windows users exposed to search-ad malvertising for developer/admin utilities; enterprises with permissive ad/script execution.	Medium
What should defenders prioritize?	Hunt for the behavioral signals and control-plane activity described in Detection Engineering and Threat Hunting.	High
Are hard IOCs available in the selected sources?	Not consistently available from accessible source snippets during this run; this report emphasizes behavior-based detection and source links.	Medium

3. Source Review & Confidence

Source	Contribution	Confidence
Elastic Security Labs	Primary malware-analysis reporting	High
Elastic Security Labs index	Publication corroboration: Lost in relocation / OXLOADER	Medium
Cyware Daily Threat Intelligence	Secondary daily threat coverage	Medium

4. Threat Actor / Campaign Overview

This activity is selected because malvertising loaders can generate broad enterprise exposure even when the final payload is commodity infostealer. The loader-specific behaviors provide detection opportunities before CASTLESTEALER credential theft completes.

5. Tactics, Techniques, and Procedures

Tactic / Phase	Observed Technique	Evidence
Initial Access	Malvertising and fake installer lures	Elastic reporting references malicious Google Ads and Node.js/API Monitor impersonation
Defense Evasion	Environment checks and obfuscated loader stages	Public snippets describe CPU, RAM, refresh-rate, geography, and emulation

		checks
Execution	Injected shellcode / in-memory payload loading	Elastic snippets describe .reloc/.xtext shellcode staging and DonutLoader wrapping

6. Infrastructure and Indicators

Indicator / Infrastructure	Type	Operational Use
No durable hard IOC published in extracted snippets	Source limitation	Use cited primary reports for any latest hashes/domains and prefer behavior hunts below.
Target-facing legitimate services	Abuse surface	Adversaries use normal web, identity, repository, advertising, or email workflows depending on campaign.

7. Victimology and Targeting

Windows users exposed to search-ad malvertising for developer/admin utilities; enterprises with permissive ad/script execution.

8. Detection Engineering

8.1. Detection Summary

Signal	Telemetry Source	Analytic Goal
New administrative rule, repository, installer, or authentication pattern inconsistent with baseline	Identity, SaaS, EDR, proxy	Surface initial access or control-plane abuse.
Script or binary execution shortly after user interaction with a lure or exposed service	EDR process telemetry	Identify payload staging and hands-on-keyboard follow-through.
External transfer or suspicious sign-in following initial signal	Network, cloud audit, identity	Detect collection/exfiltration or account takeover.

8.2. Sigma / Detection Content

<pre> title: Suspicious Campaign Follow-On Activity - oxloader-castlestealer-malvertising-loader status: experimental description: Behavioral analytic for campaign-aligned suspicious execution, authentication, or control-plane changes. Tune service names to the environment and campaign. logsource: category: process_creation detection: selection_scripting: Image endswith: - \powershell.exe - \cmd.exe - \wscript.exe - \cscript.exe - \python.exe - /bin/sh - /bin/bash selection_lure_context: CommandLine contains: - git clone </pre>

```

- npm install
- curl
- wget
- encodedcommand
- Add-MailboxRule
- Set-TransportRule
condition: selection_scripting and selection_lure_context
fields:
- Image
- CommandLine
- ParentImage
- User
- Computer
falsepositives:
- Developer administration and approved automation; require owner validation.
level: medium

```

8.3. Hunt Query

```

DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ("git clone", "npm install", "curl", "wget", "Add-MailboxRule",
"Set-TransportRule", "powershell -enc")
| where InitiatingProcessFileName has_any ("chrome.exe", "msedge.exe", "firefox.exe", "outlook.exe",
"teams.exe", "powershell.exe", "cmd.exe")
| project Timestamp, DeviceName, AccountName, InitiatingProcessFileName, FileName, ProcessCommandLine

```

9. Threat Hunting

9.1. Hunt Hypothesis

Executable downloads from ad referrals that masquerade as developer tools, create unusual PE sections, perform WMI video-controller checks, then spawn network-active child processes.

9.2. Hunt Query

```

DeviceNetworkEvents
| where Timestamp > ago(30d)
| where InitiatingProcessFileName has_any ("powershell.exe", "cmd.exe", "python.exe", "node.exe",
"git.exe", "java.exe", "splunkd.exe")
| summarize connections=count(), first_seen=min(Timestamp), last_seen=max(Timestamp),
remote_count=dcount(RemoteUrl) by DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine,
AccountName
| where connections > 10 or remote_count > 3

SigninLogs
| where TimeGenerated > ago(30d)
| summarize failures=countif(ResultType != 0), successes=countif(ResultType == 0),
countries=dcount(Location) by UserPrincipalName, AppDisplayName, IPAddress
| where failures > 20 or (successes > 0 and countries > 2)

```

10. Risk Assessment

Dimension	Assessment	Rationale
Likelihood	Medium to High	Selected because reporting is recent and defender-actionable.
Impact	High	Campaigns affect identity, research data, developer systems, or credential stores.
Confidence	high	Based on primary/vendor reporting and corroborating public coverage.

11. Recommended Actions

Priority	Owner	Action
Critical	SOC	Run the included hunts against identity, endpoint, proxy, and SaaS logs.
High	Platform / identity owners	Reduce exposed administrative surfaces and enforce phishing-resistant MFA where supported.
High	Endpoint team	Review application allowlists, browser-download controls, and developer workstation monitoring.
Medium	Threat intel	Monitor the cited primary reports for newly published IOCs and update sidecar files.

12. References

- [Elastic Security Labs] <https://www.elastic.co/security-labs/oxloader-malware-loader-infostealer>
- [Elastic Security Labs index] <https://www.elastic.co/security-labs>
- [Cyware Daily Threat Intelligence] <https://www.cyware.com/resources/threat-briefings/daily-threat-briefing/cyware-daily-threat-intelligence-june-19-2026>